



MISE EN LIGNE

# Audit avant mise en ligne

Bloquants, points importants et état de préparation du site

**Date : 16 septembre 2026.** Environnement audité : build de production local (`npm start`), base de données locale, dépôt GitHub `main`. Audit en lecture seule sur les données : aucun contenu n'a été modifié ni supprimé.

**Mise à jour du 16 septembre 2026 (soir) : site en ligne.** Le site tourne sur <https://romialkenmogne.com> (VPS, HTTPS, déploiement automatique). Les constats 1.2 à 1.6 ont été revérifiés **sur le site en ligne**, par son API publique, en lecture seule. Les listes privées (comptes, demandes, abonnés, commandes) ne sont pas lisibles sans connexion et restent à contrôler dans l'administration.

Légende : ● bloquant pour la mise en ligne · ● important · ● confort · ✓ prêt

# Sommaire

---

## Synthèse

### 1. Bloquants ●

1.1 Mise à jour de sécurité du CMS (technique) — ☒ faite le 16/09/2026

1.2 Comptes et données de test (à contrôler dans l'administration)

1.3 Contenus d'exemple en ligne

1.4 Textes juridiques

1.5 Coordonnées professionnelles — ☒ renseignées

1.6 Infrastructure et e-mail — ☒ en service

### 2. Importants ●

### 3. Confort ●

### 4. Ce qui est prêt ☒

### 5. Corrigé pendant l'audit

### 6. Ordre conseillé

# Synthèse

**Le site est en ligne ; il reste à le finaliser avant de l'annoncer.** Sécurité, performances, référencement, accessibilité, tests automatisés, infrastructure et e-mail sont en place et vérifiés. Ce qui reste relève du **contenu** (fiches d'exemple, parcours, niveaux de langue) et des **textes juridiques**, à compléter par le commanditaire.

| Domaine                           | État                                                                         |
|-----------------------------------|------------------------------------------------------------------------------|
| Sécurité (en-têtes, API, secrets) | ✅ vérifiée en ligne, Payload 3.89 · 🟠 comptes à contrôler (1.2)              |
| Performances                      | ✅ mobile 83 en moyenne, ordinateur 98 – 100 (Lighthouse, 15/09)              |
| Référencement                     | ✅ sitemap (81 adresses en ligne), robots, hreflang, métadonnées              |
| Accessibilité                     | ✅ WCAG 2.2 AA (axe) sans violation sur les pages auditées                    |
| Tests                             | ✅ 174 unitaires, 460 E2E sur 4 navigateurs, CI GitHub verte avec E2E         |
| Contenus                          | 🔴 13 fiches d'exemple en ligne ; parcours et niveaux de langue « à fournir » |
| Textes juridiques                 | 🔴 12 passages entre crochets dans 4 pages, 5 pages à faire valider           |
| Coordonnées                       | ✅ e-mail, téléphone et adresse renseignés · 🟠 réseaux sociaux vides          |
| Infrastructure                    | ✅ domaine, VPS, HTTPS, déploiement automatique, SMTP Titan (DKIM) en service |

## 1. Bloquants 🟠

### 1.1 Mise à jour de sécurité du CMS (technique) — ✅ faite le 16/09/2026

`npm audit` sur les dépendances de production : **13 alertes** (12 modérées, 1 faible, aucune élevée ou critique) avec Payload 3.88.

**Fait** : Payload et ses paquets passés en **3.89.0**, DOMPurify forcé en **3.4.15** (`overrides` du `package.json` : l'éditeur de code de l'administration l'imposait en 3.4.8). Aucune migration de base nécessaire. Vérifié : TypeScript, lint, 149 tests unitaires, build, page de connexion de l'administration, 456 tests E2E sur 4 navigateurs. **Reste 5 alertes modérées**, toutes la même faille d'esbuild, arrivée par `drizzle-kit` (outil de migration) : elle ne touche que le serveur de **développement**, jamais le site en ligne ; elle disparaîtra avec une prochaine version de Payload.

| Alerte                                                                                                                        | Portée réelle                                                                                                |
|-------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Payload : un utilisateur connecté peut débloquer le verrouillage du compte d'un autre ( <a href="#">GHSA-jg8r-5jh2-v2xj</a> ) | Administration uniquement ; risque faible avec un seul compte, mais à corriger avant d'ouvrir d'autres accès |
| DOMPurify ≤ 3.4.12 : contournements de nettoyage HTML pouvant mener à du XSS (4 alertes)                                      | Éditeur de texte de l'administration ; contenus saisis par des comptes de confiance                          |
| esbuild ≤ 0.24.2 : le serveur de <b>développement</b> répond à n'importe quel site                                            | Outils de développement seulement ; aucun effet en production                                                |

Alertes d'origine, pour mémoire (les deux premières lignes sont corrigées).

### 1.2 Comptes et données de test (à contrôler dans l'administration)

La base en ligne a été remplie par le script de démarrage avec le compte administrateur défini sur le serveur, puis utilisée pour des essais. Ces listes sont privées : elles n'ont pas été lues pendant l'audit. **Action (commanditaire)** :

- **Utilisateurs** : ne garder que les comptes réels, mot de passe fort ; supprimer tout compte d'essai ou d'exemple.
- **Demandes de contact, Abonnés newsletter, Commandes** : supprimer **une par une** les entrées créées pendant les essais (jamais de suppression en masse).

### 1.3 Contenus d'exemple en ligne

Relevé du site en ligne (16/09/2026, API publique, langue française) :

| Section                   | En ligne | Dont « Contenu d'exemple » | Action                                                                            |
|---------------------------|----------|----------------------------|-----------------------------------------------------------------------------------|
| Écosystème (activités)    | 5        | 5                          | Relire les descriptions des 5 activités, puis décocher « Contenu d'exemple »      |
| Expériences et projets    | 3        | 3                          | Fiches « [...] à fournir » : remplacer par les expériences vérifiées ou supprimer |
| Formations et certificats | 2        | 2                          | Fiches « [...] à fournir » : intitulés exacts ou suppression                      |
| Articles RK Insights      | 3        | 3                          | Décider : conserver, remplacer ou supprimer                                       |
| Domaines d'expertise      | 8        | 0                          | ✅ (relecture DE/EN conseillée)                                                    |
| Livres                    | 1        | 0                          | ✅ (prix non renseigné : facultatif, les liens Amazon s'affichent)                 |
| Conférences & médias      | 0        | 0                          | ✅ la fiche « test » de la base locale n'a pas été reprise en ligne                |
| Médiathèque               | 4        | —                          | ✅ textes alternatifs renseignés ; les deux images de test locales sont absentes   |

**Page À propos** (FR, DE, EN) : le **parcours professionnel** commence encore par « [Parcours professionnel à fournir.] » et les **3 niveaux de langue** affichent « [Niveau] ».

Chaque contenu d'exemple affiche un bandeau « Contenu d'exemple » sur le site public : aucun ne doit rester publié le jour de l'annonce.

### 1.4 Textes juridiques

Les **5 pages légales** portent toujours la case « à faire valider par un juriste » (bandeau visible, `noindex`, exclues du sitemap). Passages entre crochets relevés en français :

| Page                         | Passages à compléter | Contenu attendu                                                                                          |
|------------------------------|----------------------|----------------------------------------------------------------------------------------------------------|
| Impressum / Mentions légales | 4                    | Raison sociale, siège, registre, TVA ; responsable de publication ; e-mail et téléphone ; hébergeur      |
| Politique de confidentialité | 4                    | Responsable de traitement ; passage « à valider » ; prestataire e-mail (Titan) ; adresse pour les droits |
| Conditions générales         | 3                    | Texte à rédiger et à valider juridiquement                                                               |
| Politique de cookies         | 1                    | Outils réellement utilisés (aucun outil de mesure activé aujourd'hui)                                    |
| Livraison et retours         | 0                    | Validation juridique seulement                                                                           |

**Action** : compléter dans les trois langues, faire valider par un professionnel du droit, puis décocher la case. L'Impressum et la politique de confidentialité sont obligatoires en Allemagne dès que le site est public.

### 1.5 Coordonnées professionnelles — ✅ renseignées

E-mail ( `contact@romialkenmogne.com` ), téléphone et adresse professionnelle sont renseignés dans **Réglages du site**. Restent vides : réseaux sociaux (2.4), documents PDF (2.3), lien de rendez-vous (3) et SEO par défaut (titre, description, image : les valeurs du site s'appliquent).

## 1.6 Infrastructure et e-mail — en service

- Domaine `romialkenmogne.com`, VPS Linux, Apache en proxy, certificat Let's Encrypt, redirections `http` → `https` et `www` → domaine nu.
- Déploiement automatique après chaque CI verte (image GHCR, sauvegarde avant mise à jour, retour automatique à l'image précédente si le contrôle de santé échoue) : voir `DEPLOIEMENT.md` §3.
- SMTP Titan (`contact@romialkenmogne.com`, port 465, DKIM `titan2`) vérifié depuis le conteneur.
- **Reste à faire (commanditaire)** : test réel du formulaire de contact et de la newsletter en ligne (réception, dossier spam), contrôle SPF / DKIM / DMARC, sonde de disponibilité sur `/api/health`, puis le reste de la checklist `DEPLOIEMENT.md` §13.

## 2. Importants

| #   | Constat                                                                                                                                                                                                                                                         | Action                                                                                                                |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| 2.1 | <b>Boutique ouverte</b> dans l'administration (case cochée), <b>TVA à 19 %</b> , aucune adresse de notification des commandes. Aucun paiement n'est proposé tant que les clés manquent, mais la case ne doit pas rester cochée sans CGV validées                | Décocher jusqu'à l'ouverture réelle ; faire valider le taux par le comptable (les livres relèvent en principe de 7 %) |
| 2.2 |  <b>Image de partage social</b> : depuis le 16/09, image par défaut en PNG 1200 × 630 avec le nouveau logo (l'ancienne, en SVG, n'était pas affichée par LinkedIn et Facebook) | Facultatif : la remplacer par une photo ou un visuel propre (Réglages du site → SEO par défaut)                       |
| 2.3 | <b>International Expert Profile</b> et <b>CV</b> non téléversés : les boutons de téléchargement restent masqués                                                                                                                                                 | Téléverser les PDF (Réglages du site → Marque)                                                                        |
| 2.4 | <b>Réseaux sociaux</b> : aucun profil, la section du pied de page est masquée                                                                                                                                                                                   | Ajouter au moins LinkedIn (guide administrateur §10)                                                                  |
| 2.5 | <b>Échecs ponctuels de requêtes au CMS</b> sous forte charge ( <code>ECONNRESET</code> ) : le site sert alors le contenu de démarrage, qui peut rester en cache 5 minutes                                                                                       | Chantier « fiabiliser le CMS » : limiter les connexions, ne pas mettre en cache le contenu de secours                 |
| 2.6 | <b>HSTS</b> envoyé avec <code>includeSubDomains; preload</code>                                                                                                                                                                                                 | Garder seulement si <b>tous</b> les sous-domaines sont en HTTPS ; ne soumettre à la liste de préchargement qu'ensuite |
| 2.7 | <b>Relectures</b> DE/EN : biographie, domaines d'expertise, fiche livre                                                                                                                                                                                         | Relecture par un locuteur natif                                                                                       |

## 3. Confort

- Lien de prise de rendez-vous non renseigné (bouton masqué).
- Logo : nouveau logo (anneau marine et or, R et K) intégré le 16/09 dans l'en-tête, le pied de page, les icônes, l'image de partage, l'administration et les PDF. Les lettres utilisent la police Playfair Display : pour l'impression professionnelle, prévoir une version vectorisée (lettres converties en tracés) par un graphiste.
- Prix, éditeur, date de parution et nombre de pages du livre facultatifs.
- La 404 d'une **fiche** inexistante est complétée par JavaScript (statut 404 et `noindex` corrects) ; limite connue et acceptée.
- Plantages ponctuels de Node (code `0xc0000409`) observés sous Windows pendant les tests locaux ; à surveiller sur le serveur Linux (redémarrage automatique du conteneur prévu).
- Intégration CRM / e-mail marketing : décision ouverte (l'export CSV couvre le besoin immédiat).

## 4. Ce qui est prêt

### Sécurité

- En-têtes vérifiées sur la réponse du serveur : `Content-Security-Policy`, `Strict-Transport-Security`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `Permissions-Policy`, sans en-tête `X-Powered-By`.
- Administration en `X-Robots-Tag: noindex, nofollow` et exclue de `robots.txt`.
- API du CMS (`/api/cms`) : sans connexion, les collections privées (utilisateurs, demandes de contact, commandes, abonnés, membres, accès aux produits, fichiers protégés) et les réglages de la boutique répondent **403** ; les contenus publics ne renvoient aucun brouillon ; GraphQL désactivé. Contrôle automatisé dans `content.spec.ts`.
- `PAYLOAD_SECRET` refusé au démarrage s'il est vide, par défaut ou trop court ; CORS et CSRF limités à l'adresse du site.
- Aucun secret dans le dépôt ; aucun `console.log`, `TODO` ou `FIXME` oublié dans le code.
- Formulaire : validation serveur, anti-robot, limitation de débit ; paiements jamais simulés, webhook Stripe signé.

### Performances et référencement

- Lighthouse (15/09, 12 pages) : mobile **83** en moyenne, ordinateur **98 – 100**, accessibilité et bonnes pratiques **100**.
- `sitemap.xml` (82 adresses) avec variantes de langue, `robots.txt`, balises canoniques et `hreflang`, données structurées, pages mises en cache 5 minutes.
- Médias : chaque image a un texte alternatif en français (voir 1.3 pour deux images de test sans version anglaise ni allemande).

### Qualité et exploitation

- 174 tests unitaires, 132 scénarios E2E × 4 navigateurs (460 réussis), intégration continue GitHub avec E2E sur base jetable.
- Point de santé `/api/health` (base de données vérifiée, `ok` en ligne), scripts de sauvegarde et de restauration testés, migrations versionnées, image Docker de production, déploiement automatique avec retour arrière.
- Administration : pastilles de notification pour les nouvelles demandes de contact et les nouveaux abonnés (guide administrateur §5 et §15).
- Guides administrateur, installation, déploiement et rapport de tests en PDF.

## 5. Corrigé pendant l'audit

| Constat                                                                                                                                                                                                                                       | Correction                                                                                                                    |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Le sitemap publiait des adresses vides ( <code>/en/speaking/</code> , <code>/de/speaking/</code> ) pour un contenu traduit dans une seule langue : un robot aurait suivi une adresse redirigée vers une liste                                 | Une langue n'est plus listée quand le contenu n'y a pas de slug ; variantes <code>hreflang</code> idem                        |
| L'adresse de <b>réception des demandes de contact</b> (Réglages du site) était lisible par tous via <code>/api/cms/globals/site-settings</code> ; et le formulaire l'ignorait (envoi à <code>EMAIL_TO</code> , contrairement au texte d'aide) | Champ lisible par l'équipe seulement ; le formulaire l'utilise en priorité, puis <code>EMAIL_TO</code> , puis l'e-mail publié |
| Dépéances : 13 alertes (Payload 3.88, DOMPurify 3.4.8)                                                                                                                                                                                        | Payload 3.89.0 et DOMPurify 3.4.15 ; reste l'alerte esbuild de développement (1.1)                                            |

## 6. Ordre conseillé

1. **Technique** : mise à jour Payload 3.89 (1.1) faite ; **Infrastructure** : domaine, hébergement, HTTPS, SMTP (1.6) faite ; coordonnées (1.5) renseignées.
2. **Juridique (commanditaire + juriste)** : compléter et faire valider les pages légales (1.4), en priorité l'Impressum et la politique de confidentialité ; boutique fermée tant que la vente directe n'est pas prête (2.1).
3. **Contenus (commanditaire)** : parcours et niveaux de langue de la page À propos, remplacer ou supprimer les 13 fiches d'exemple (1.3), réseaux sociaux et PDF (2.3, 2.4).
4. **Nettoyage (commanditaire)** : comptes et données de test, une entrée à la fois (1.2).

5. **Avant l'annonce** : tests réels des e-mails, SPF / DKIM / DMARC, reste de la checklist `DEPLOIEMENT.md` §13, Lighthouse sur le domaine final, soumission du sitemap à la Search Console.